

# **MENACES INFORMATIQUES ET CODES MALVEILLANTS ANALYSE ET LUTTE**

**Exploitation et  
analyse des traces réseaux**

### 2

## Sommaire



Connaître et comprendre les protocoles d'intérêt à la cybersécurité



Connaître et identifier les attaques



Connaître des outils de surveillance du réseau pour la prévention et l'investigation



Bonnes pratiques pour la collecte des journaux réseaux



Investiguer et analyser du trafic dans un réseau compromis par un acteur malveillant



Enseignant-chercheur à Université Paul Sabatier (STRI – SSIR – SSIR & IRIT)

Dirigeant de la société CYBERFABLAB Expertises et formations

Expert de justice E-INDUSTRIE (Informatique section E01.02 à E01.04) & CRIMINALISTIQUE (G-02.05)

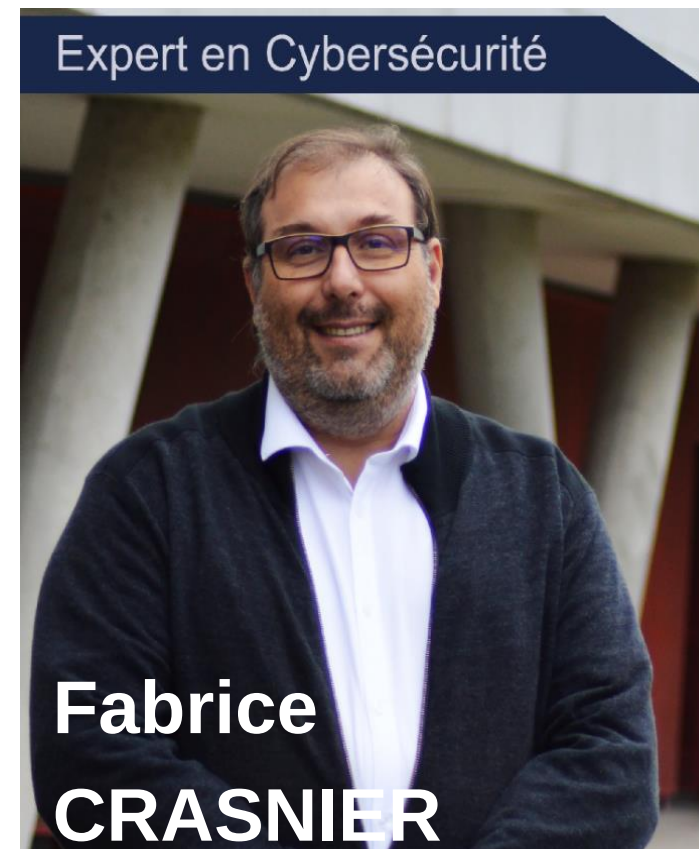
Après un cursus **d'Ingénieur en conception et développement** informatique, je me suis dirigé vers la recherche sur l'informatique embarqué puis sur l'apprentissage automatique supervisé. A cet effet, je termine un **doctorat en intelligence artificielle** distribuée à l'école doctoral de Toulouse.

Durant 27 ans au service des unités de recherches de la Gendarmerie Nationale, dont 17 années consacrées au suivi de la cyberdélinquance en tant **enquêteur NTECH**, j'ai mis en place les équipes d'investigations en cybercriminalité de la section des recherches à partir de 2002 et de la section d'appui judiciaire de Toulouse à compter de 2013.

A partir de 2017, j'ai pu mettre en place le laboratoire SCASSI-CYBER en qualité de **Consultant Expert Senior** au sein de la société SCASSI, où j'ai exercé durant 3 ans au poste de responsable des activités de réponse sur incidents de sécurité et des expertises légales (FORENSIC) puis durant un an environ en tant que **directeur de la recherche et du développement** au sein de la société FREEMINTRONIC à Andorre.

Je suis actuellement **enseignant-chercheur** à l'université Paul Sabatier à TOULOUSE en tant que **Maître de conférences associé** où j'enseigne diverses matières en lien avec la cybersécurité allant de l'audit de maturité au recours devant les tribunaux pour les activités de cybercriminalité. Je mène en parallèle mon activité de **dirigeant** d'entreprise dans la recherche et le développement nommée **CYBERFABLAB** et celle **d'expert de justice auprès de la Cour d'Appel de TOULOUSE**

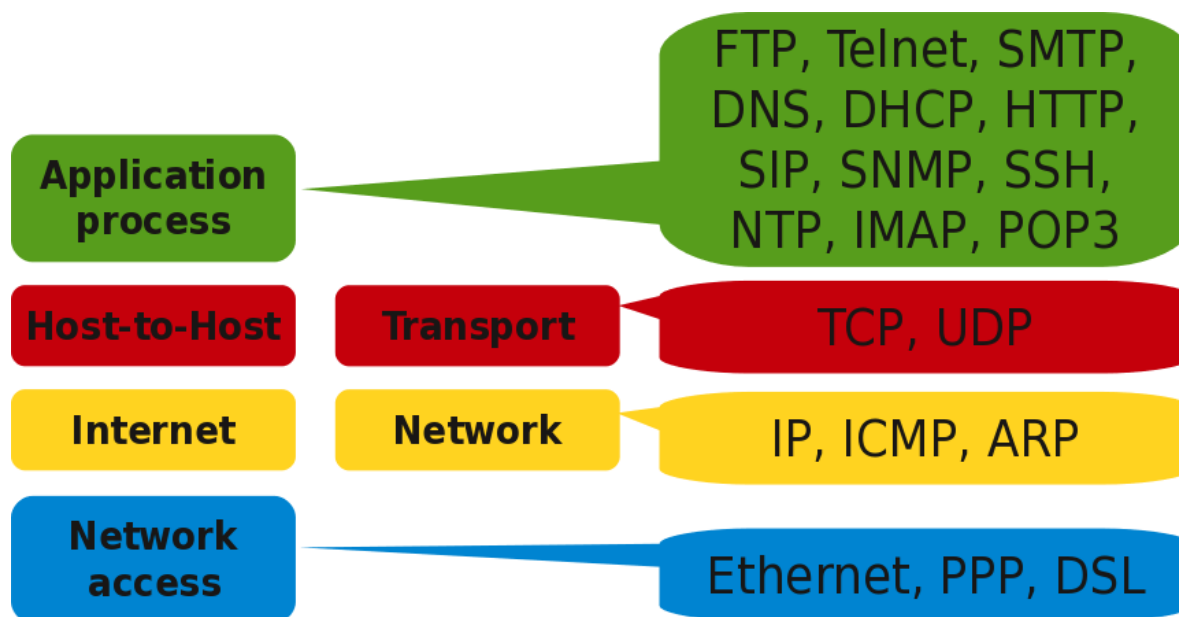
Expert en Cybersécurité



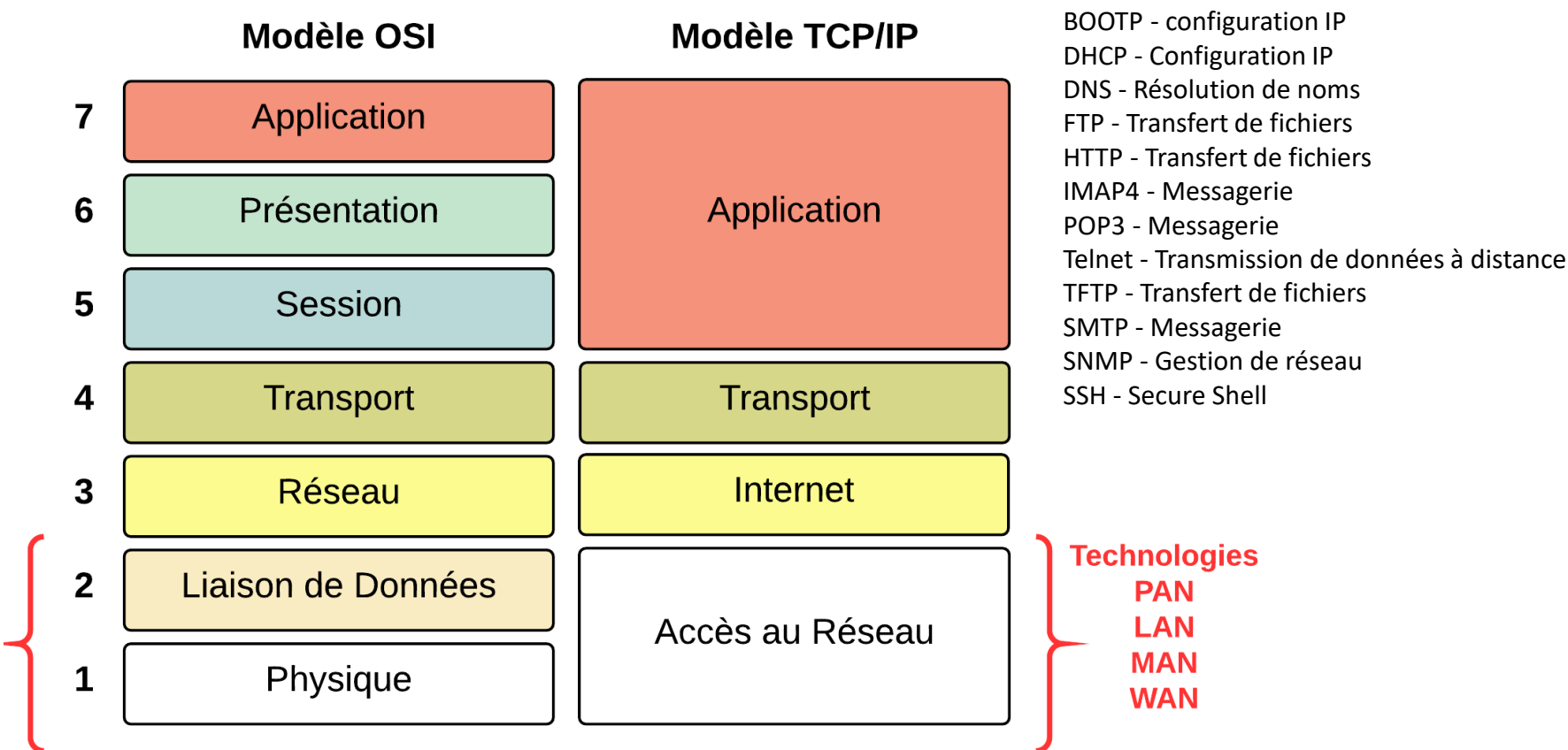
Fabrice  
CRASNIER

- **Rappel sur les protocoles**
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

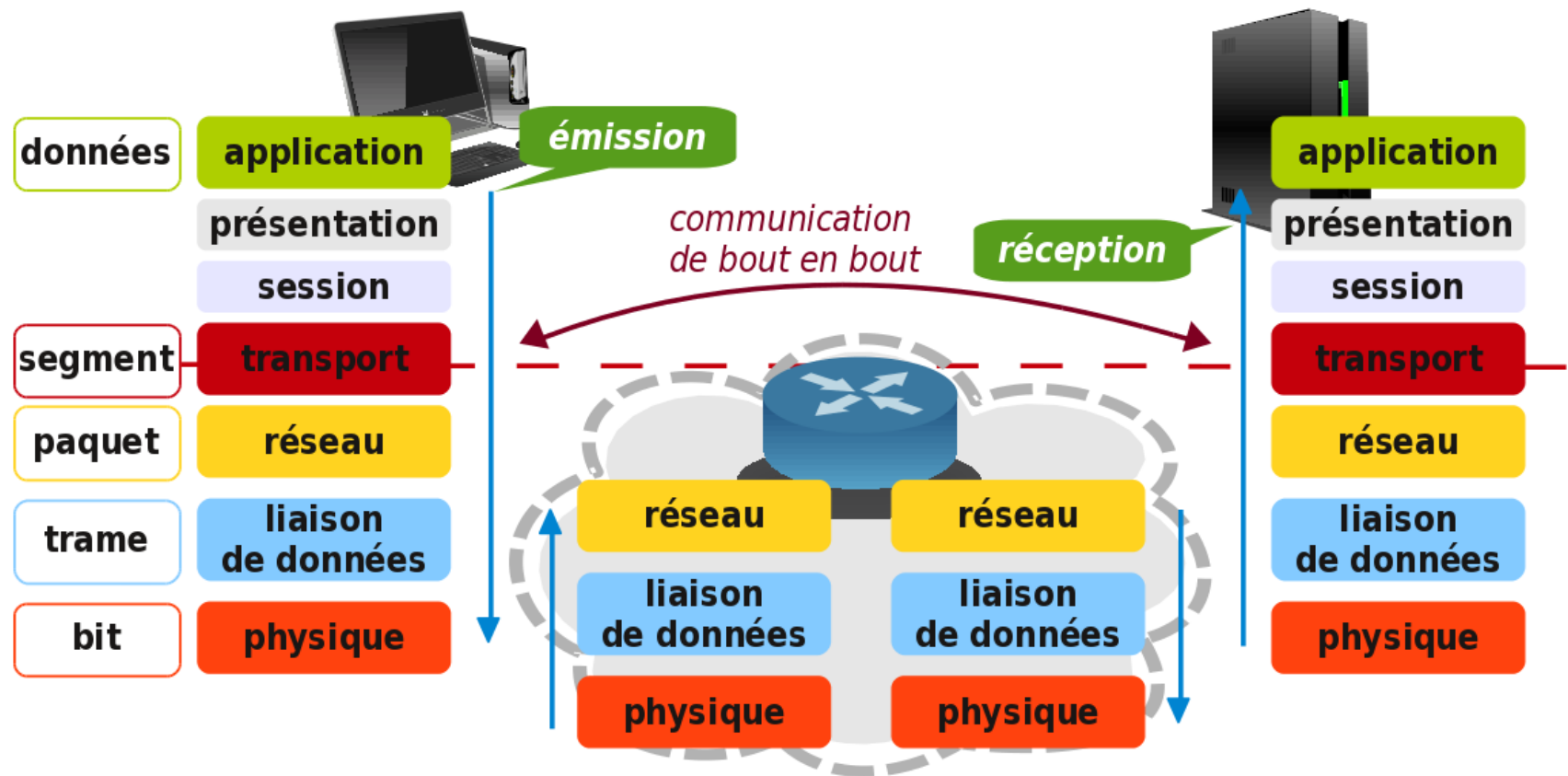
### Connaître et comprendre les protocoles d'intérêt à la cybersécurité



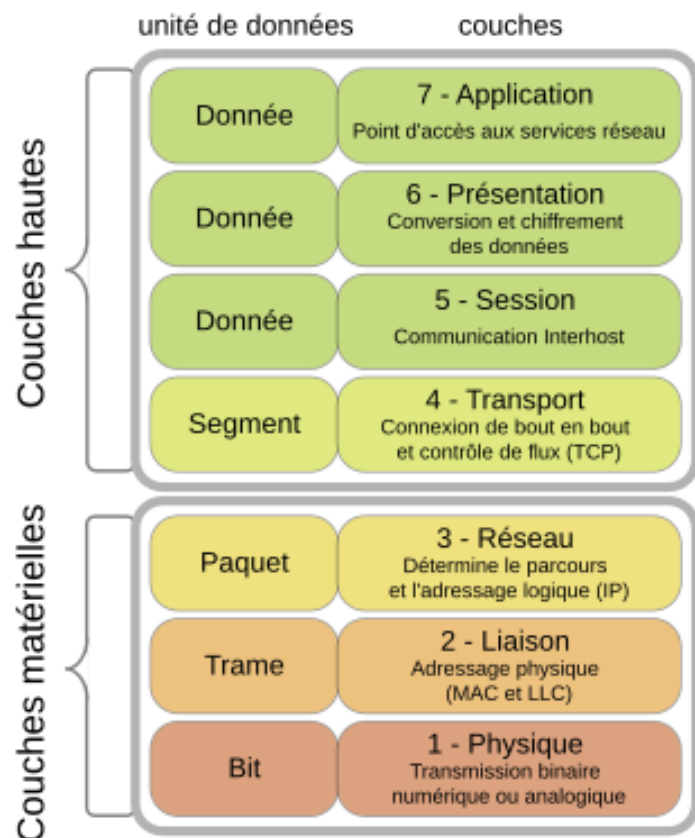
## Rappel sur les protocoles



### Rappel sur les protocoles



## Rappel sur les protocoles



## La couche présentation (6e couche du modèle OSI)

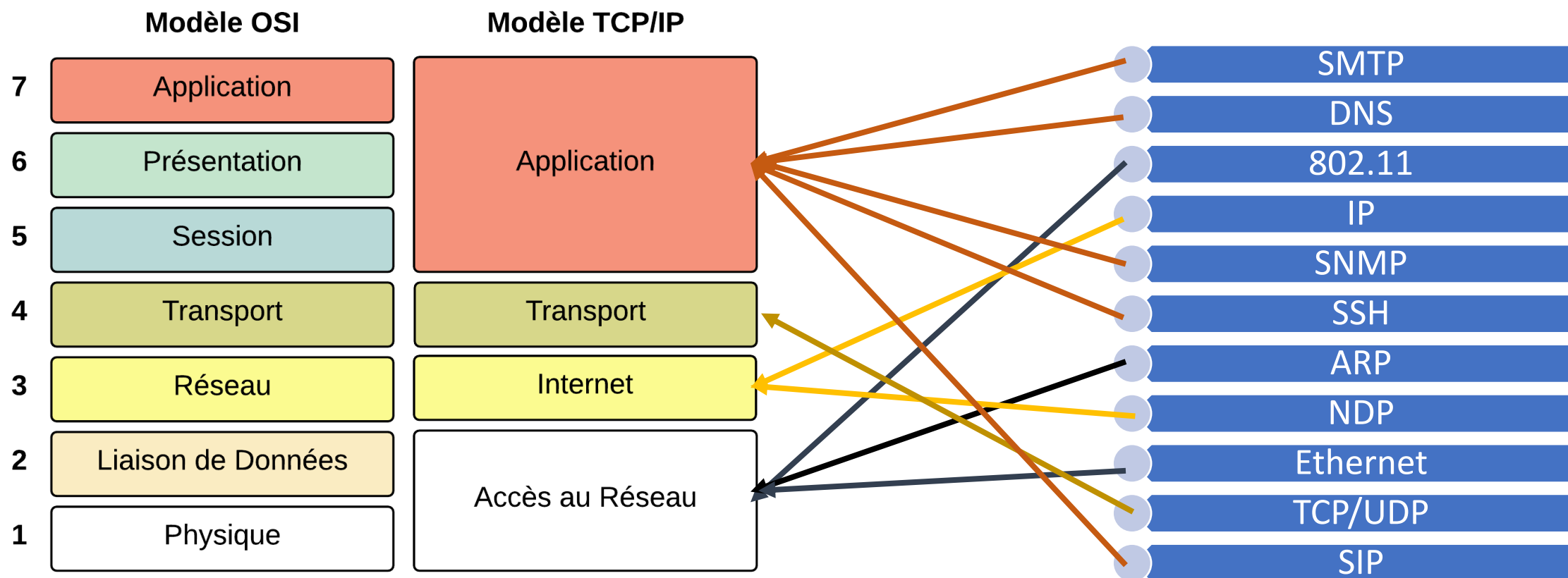
- Conversion de code caractère (par exemple ASCII/EBCDIC)
- Conversion de données (par exemple CR - CR/LF)
- Compression
- Chiffrement et déchiffrement

La couche session (5<sup>e</sup> couche du modèle OSI)

- RPC (Remote Procedure Call)
- NetBIOS (Network Basic Input/Output System)
- PPTP (Point-to-Point Tunneling Protocol)
- SIP (Session Initiation Protocol)
- SOCKS (Socket Secure)

## 8

## Rappel sur les protocoles





- Rappel sur les protocoles
- **Les différents types de journaux réseaux**
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

### Les différents types de journaux réseaux



## Les différents types de journaux réseau

### Capture de paquets :

- Bruts ou Verbeux
- Intéressant dans le cadre d'une analyse à cours terme pointue (analyse malware par exemple)

```
▶ Internet Protocol Version 4, Src: 0.0.0.0, Dst: 255.255.255.255
▶ User Datagram Protocol, Src Port: 68, Dst Port: 67
▼ Dynamic Host Configuration Protocol (Discover)
  Message type: Boot Request (1)
  Hardware type: Ethernet (0x01)
  Hardware address length: 6
  Hops: 0
  Transaction ID: 0x88255f41
  Seconds elapsed: 0
  ▶ Bootp flags: 0x0000 (Unicast)
    Client IP address: 0.0.0.0
    Your (client) IP address: 0.0.0.0
    Next server IP address: 0.0.0.0
    Relay agent IP address: 0.0.0.0
```



La capture de paquets consiste à **capturer des paquets IP** à des fins de dépannage, de contrôle de sécurité ou autres. Elle peut également être utilisée à des fins malveillantes.

Contrairement aux techniques de reconnaissance active telles que le **balayage de ports** (*NMAP*), la capture de paquets peut être effectuée sans laisser de traces visibles aux investigateurs.

|    |              |             |               |      |    |                      |      |
|----|--------------|-------------|---------------|------|----|----------------------|------|
| 65 | 71.549863828 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 66 | 71.550442859 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |
| 67 | 72.574374708 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 68 | 72.575076914 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |
| 69 | 73.598327570 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 70 | 73.599064471 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |
| 71 | 74.621088635 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 72 | 74.621629266 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |
| 73 | 74.636028609 | 172.16.55.1 | 172.16.55.255 | UDP  | 86 | 57621 → 57621 Len=44 |      |
| 74 | 75.645573336 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 75 | 75.646163847 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |
| 76 | 76.669746702 | 172.16.55.4 | 172.16.55.1   | ICMP | 98 | Echo (ping) request  | id=0 |
| 77 | 76.670227903 | 172.16.55.1 | 172.16.55.4   | ICMP | 98 | Echo (ping) reply    | id=0 |

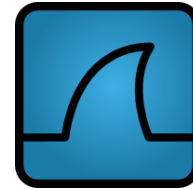
## Les différents types de journaux réseau

## Outils de capture de paquets :

- Wireshark (<https://www.wireshark.org>)
- Kismet (<https://www.kismetwireless.net>)
- Tcpcdump
- Packet Monitor (Pktmon)
- Microsoft Network Monitor 3.4



**tcpdump** est un analyseur de paquets en ligne de commande. Il permet d'obtenir le détail du trafic visible depuis une interface réseau. L'outil distribué par les distributions GNU/Linux, FreeBSD, NetBSD, OpenBSD et Mac OS X dépend de la bibliothèque logicielle libpcap.



Wireshark

**Wireshark** est un analyseur de paquets libre et gratuit. Il est utilisé pour le dépannage et l'analyse des réseaux, ainsi que pour le développement de logiciels et de protocoles de communication.



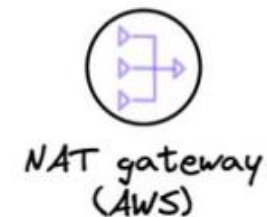
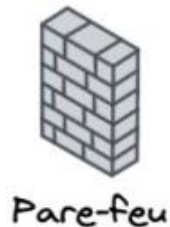
Kismet

**Kismet** est un renifleur, un WIDS et un outil de surveillance pour Wi-Fi, Bluetooth, Zigbee, RF, etc., qui fonctionne sous Linux et macOS

### Les différents types de journaux réseau

#### Fichiers de logs :

- Moins verbeux (information légère et plus pertinente)
- Sources multiples: Serveurs, Pares-feux, NIDS/NIPS, Endpoint, ...



**Problème : Taxonomie et format des logs très hétérogène !**



- Rappel sur les protocoles
- Les différents types de journaux réseaux
- **Techniques, tactiques et procédures des attaquants**
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

### Techniques, tactiques et procédures des attaquants



### Techniques, tactiques et procédures des attaquants

Attaques par déni de service distribué (DDOS)

Scans massifs et tentatives d'exploitation de vulnérabilités (nmap, wfuzz, ...)

Hameçonnage : Campagnes de phishing, spearphishing...

L'ensemble des protocoles exposés est à considérer comme prioritaire dans la surveillance et lors d'une investigation numérique.

15

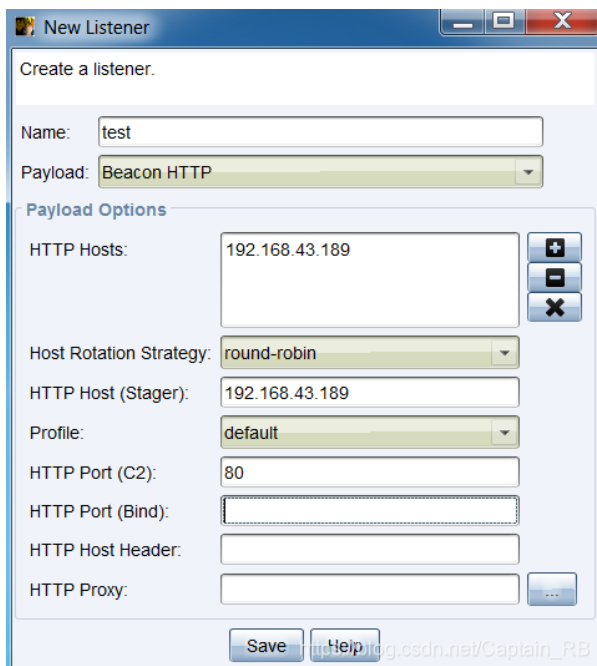
## Techniques, tactiques et procédures des attaquants

### Détournement des protocoles http/https

**Cobalt Strike** est un outil de sécurité légitime employé par les experts en tests d'intrusion pour émuler une activité cybercriminelle sur un réseau. Toutefois, il est de plus en plus utilisé par les cybercriminels.

Un beacon est une **charge utile malveillante** déployée sur une machine compromise. Son rôle principal est de fournir une connexion persistante entre l'attaquant et la machine cible, permettant des actions de commande et contrôle (**C2**) sur celle-ci.

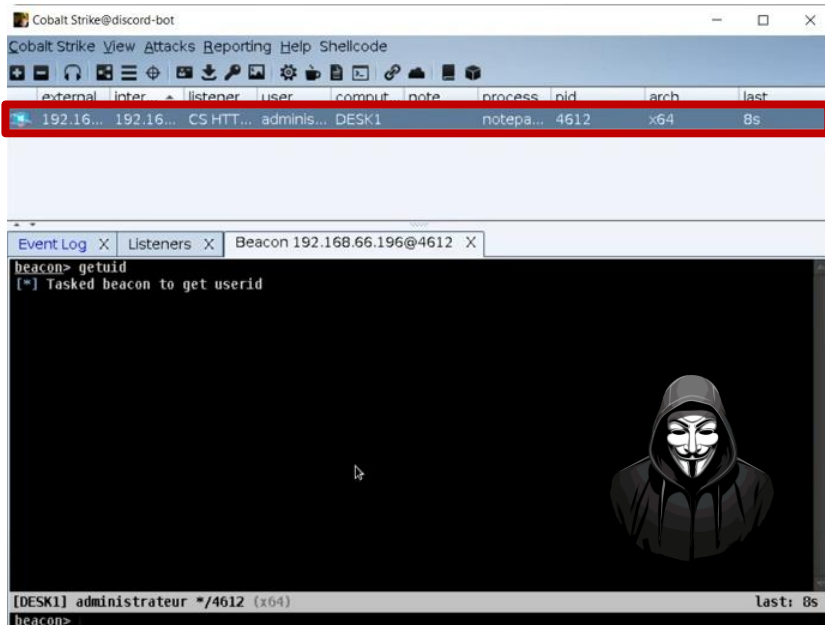
*Création des outils à destination d'une victime*



<https://www.youtube.com/watch?v=CHk2XzFKwNc>

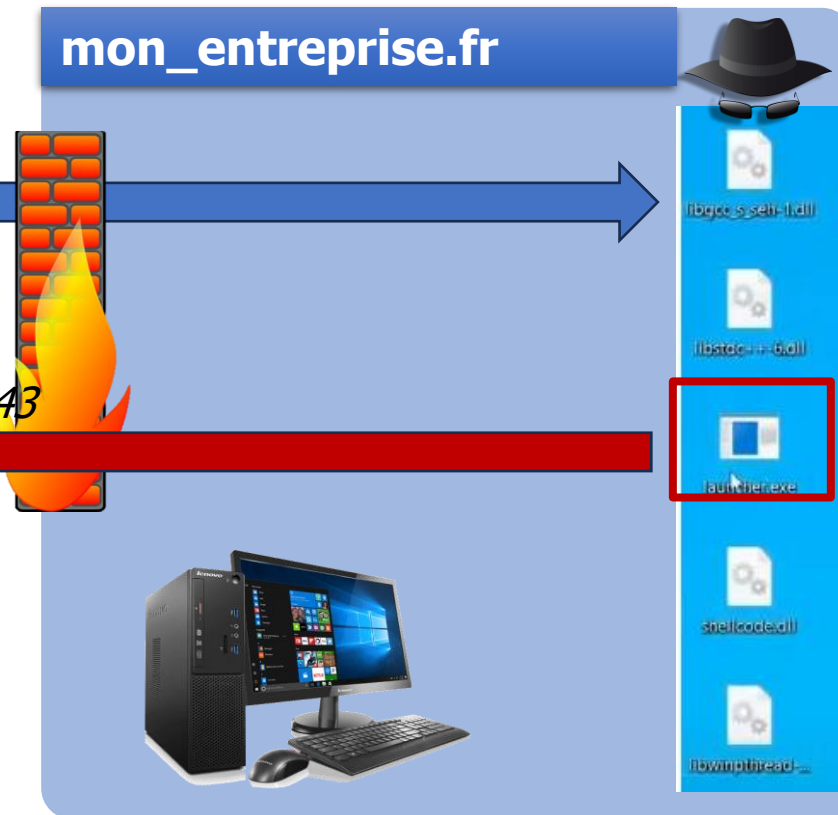
# Techniques, tactiques et procédures des attaquants

# Détournement des protocoles http/https



*Compromission iniziale (par mail, etc.)*

### Command & Control (C2) – Port 80/443



### Techniques, tactiques et procédures des attaquants

#### Détection et investigation

Analyse de paquets : Rechercher des données qui sortent de l'ordinaire (analyse statistique)

Analyse de trafic : Comparer les requêtes HTTP à un trafic « usuel »

Historique des domaines contactés => Recherche de « nouveaux » domaines

Analyse sur l'enregistrement des domaines (whois) / Réputation des domaines (VirusTotal...)



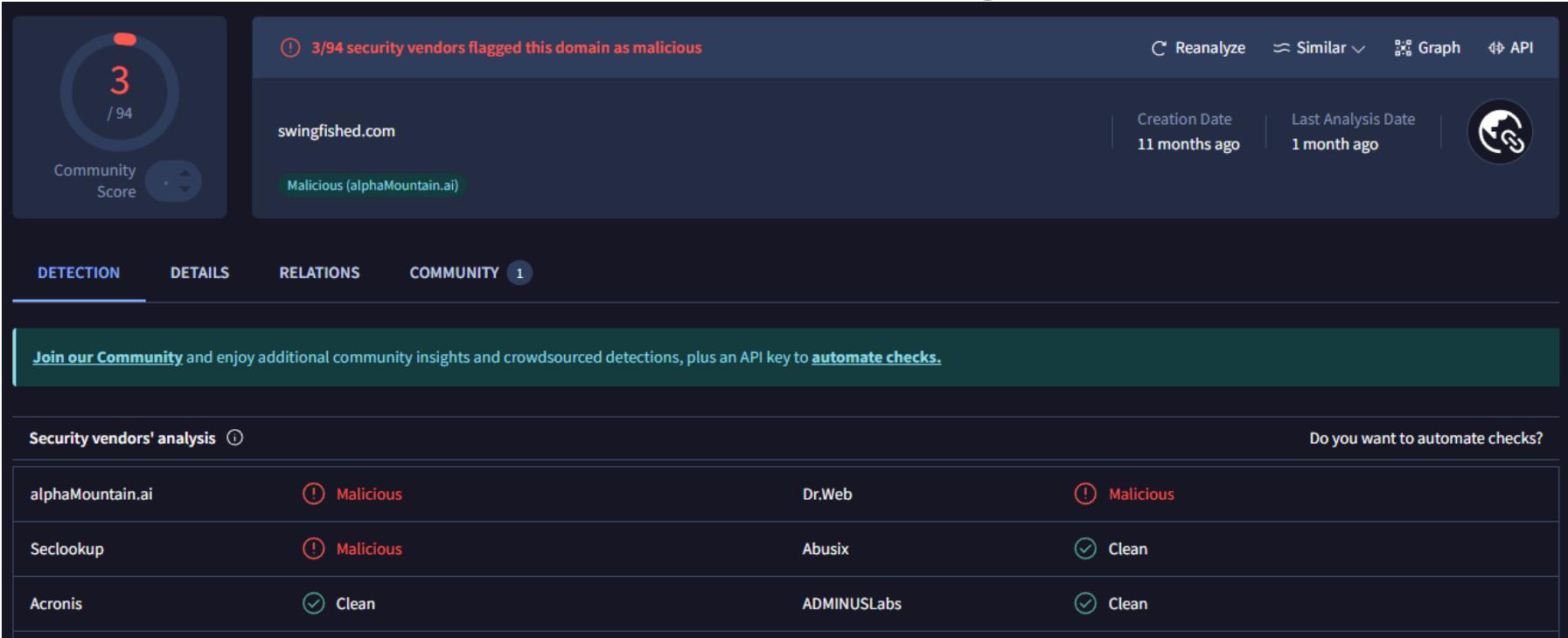
## Techniques, tactiques et procédures des attaquants

## Détection et investigation



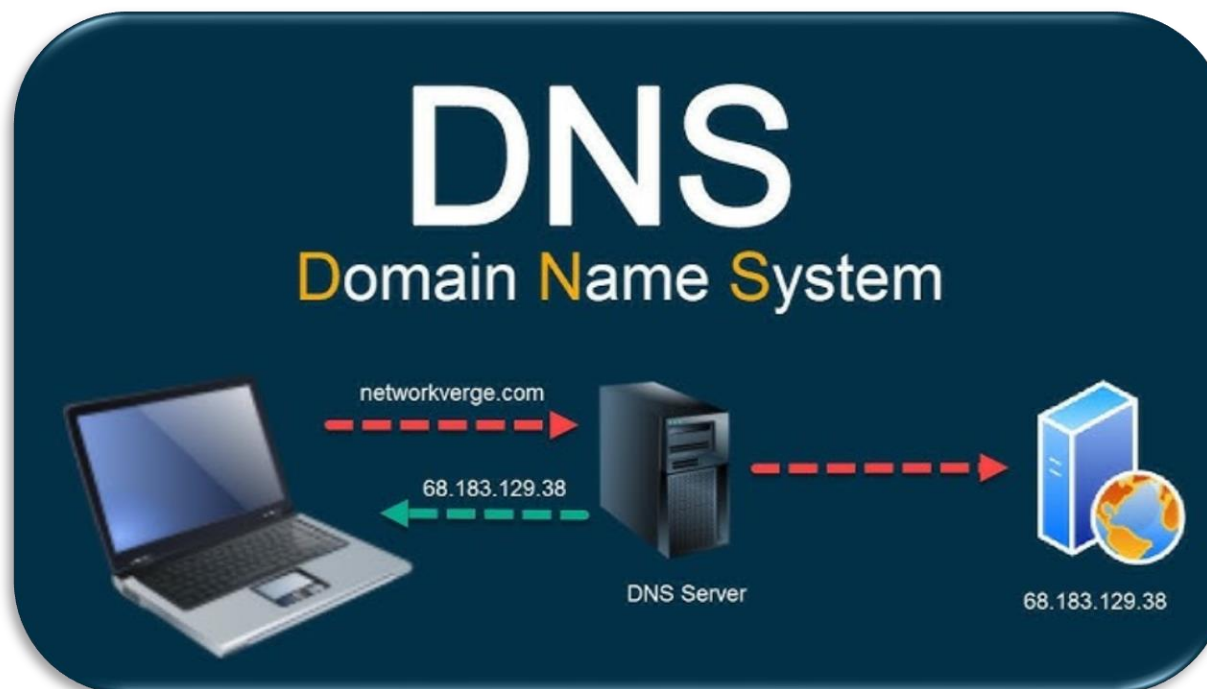
## Techniques, tactiques et procédures des attaquants

### Détection et investigation



### Techniques, tactiques et procédures des attaquants

#### Détournement du protocole DNS

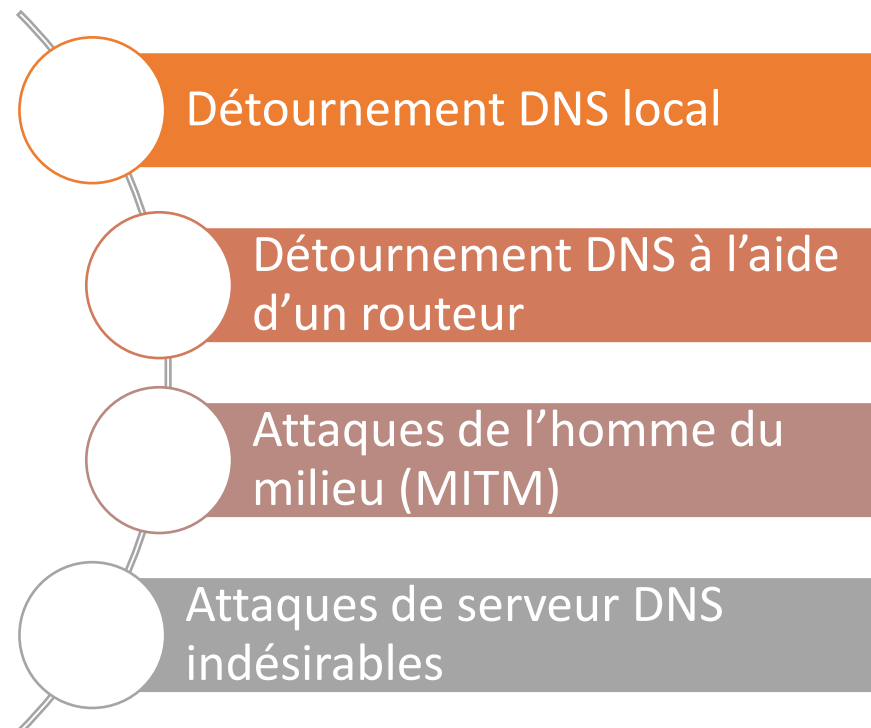


## Techniques, tactiques et procédures des attaquants

### Détournement du protocole DNS

Le **détournement de serveur de noms de domaine (DNS)** est un type d'attaque DNS où un attaquant manipule intentionnellement la manière dont les requêtes DNS sont résolues afin de rediriger les utilisateurs vers des sites Web malveillants.

Les pirates informatiques installent des **logiciels malveillants** sur les PC des utilisateurs, prennent le contrôle des routeurs, interceptent ou piratent les connexions DNS pour mener l'attaque.



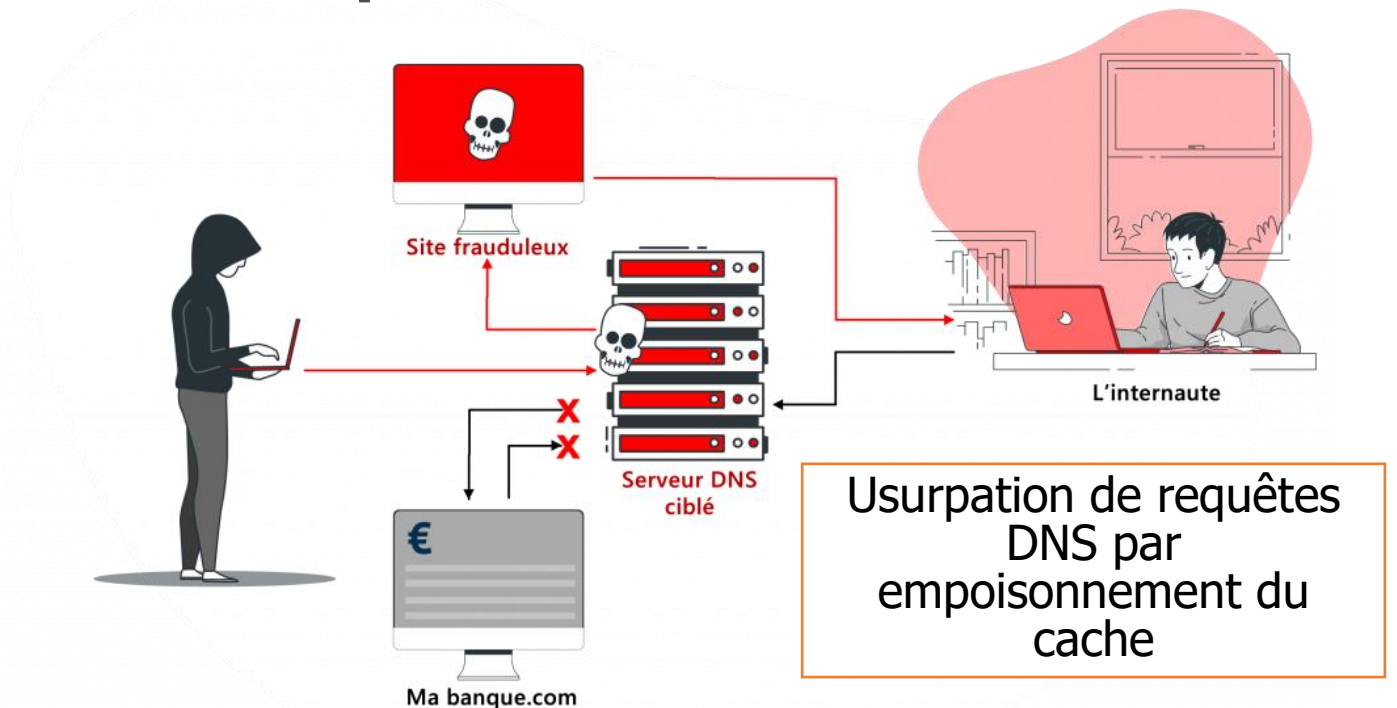
# Techniques, tactiques et procédures des attaquants

# Détournement du protocole DNS

## Comment lutter contre le DNS spoofing ?

Le DNS Spoofing est une cyberattaque visant le DNS qui consiste à rediriger les internautes à leur insu vers des sites frauduleux cherchant à voler les informations récoltées.

Pour lutter efficacement contre le spoofing, la mise en place du **DNSSEC** sur vos noms stratégiques est la solution.

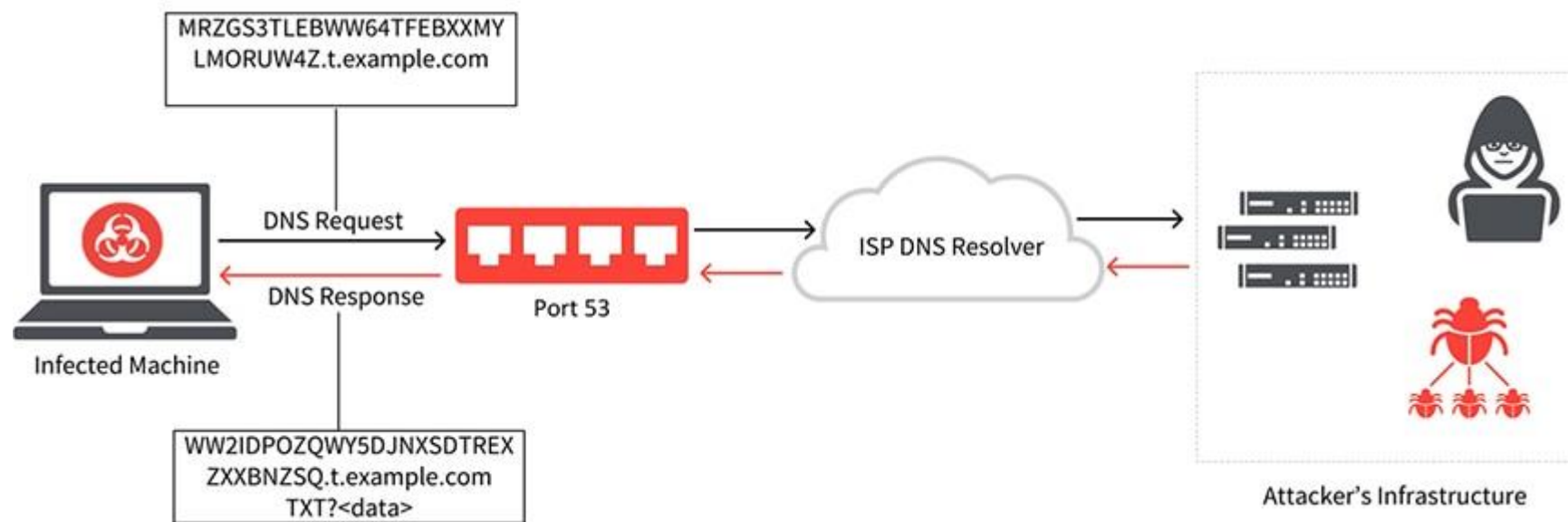


## Techniques, tactiques et procédures des attaquants

## Détournement du protocole DNS

Le serveur du nom de domaine pointe vers le serveur de l'attaquant sur lequel un malware de tunneling est installé.

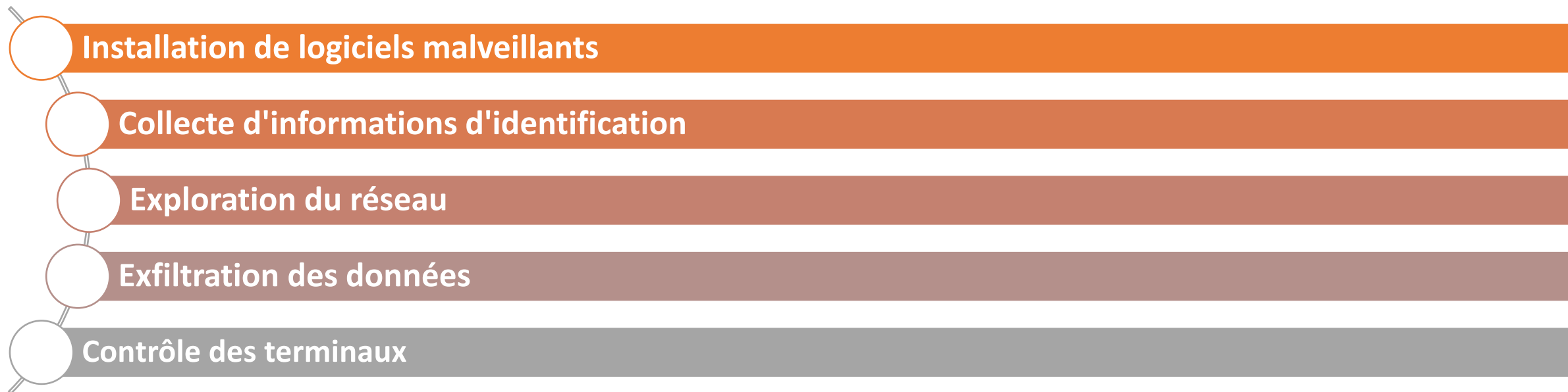
L'attaquant utilise le malware pour infecter l'ordinateur de sa victime qui, la plupart du temps, est protégé par le pare-feu de l'entreprise





### Techniques, tactiques et procédures des attaquants

**La tunnellation DNS permet aux pirates  
d'effectuer diverses activités malveillantes**



### Techniques, tactiques et procédures des attaquants

#### Détection et investigation

- **Blocage des noms de domaines** (ou des adresses IP/régions géographiques) en fonction de leur réputation ou de la menace qu'ils représentent
- **Déploiement de règles** pour identifier les chaînes de caractères suspectes dans les requêtes DNS
- **Restrictions concernant la longueur**, le type ou la taille des requêtes DNS entrantes et sortantes
- **Durcissement des systèmes d'exploitation clients**, sensibilisation aux capacités de résolution des noms et à l'ordre de recherche
- **Analyse des comportements des utilisateurs et/ou des systèmes** pour identifier automatiquement les anomalies, par exemple des méthodes ou une fréquence d'accès à de nouveaux domaines jugées atypiques

### Techniques, tactiques et procédures des attaquants

#### Détection et investigation

- Analyse de paquets : Rechercher des données qui sortent de la normale (analyse statistique)
- Analyse de trafic : Comparer les requêtes DNS à un trafic « usuel » (Ex : identifier les requêtes de type TXT record).
- Exemple d'une requête DNS suspecte : MRZGS3TLEBWW64TFEBXXMYLMORUW4ZI.t.example.com.
- Historique des domaines contactés.
- Géolocalisation des IPs : Attention néanmoins, fiabilité variable dans le temps.
- Le nombre de nom d'hôtes par domaine (une requête unique par nom de domaine).
- La visualisation ! Le trafic DNS malveillant saute à l'œil directement lors de construction de graphiques.

27

## Techniques, tactiques et procédures des attaquants

## Les protocoles ciblés sur LINUX : FTP / TELNET

Un protocole dont les échanges sont « en clair » sur le réseau. Créé pour transférer des fichiers de manière très facile.

Comme tout vieux protocole : Pas pensé avec une dimension sécurité. Son usage peut être dérivé.

Risques :

- MITM
- Exfiltration de données

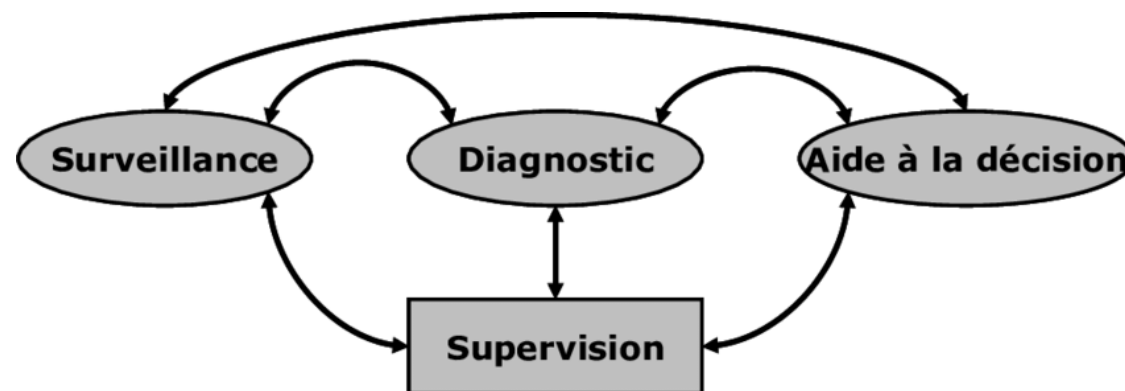
The image shows a Wireshark capture of an FTP session (ftp.pcap). The packet list on the left shows several packets, with packet 4 highlighted. The packet details pane on the right shows the FTP protocol structure, with the 'Response: 530 Login incorrect.' message highlighted. The packet bytes pane at the bottom shows the raw data of the selected packet, including the ASCII representation of the response message.

| No. | Time     | Source         | Destination    | Protocol | Info                                       |
|-----|----------|----------------|----------------|----------|--------------------------------------------|
| 4   | 0.012755 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 530 Login incorrect.             |
| 10  | 0.031952 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 331 Password required for admin. |
| 11  | 0.032425 | 10.234.125.254 | 10.121.70.151  | FTP      | Request: PASS merlin                       |
| 13  | 0.040913 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 530 Login incorrect.             |
| 16  | 0.050057 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 331 Password required for admin. |
| 17  | 0.051363 | 10.234.125.254 | 10.121.70.151  | FTP      | Request: PASS mercury                      |
| 19  | 0.052900 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 331 Password required for admin. |
| 20  | 0.059083 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 331 Password required for admin. |
| 21  | 0.059593 | 10.234.125.254 | 10.121.70.151  | FTP      | Request: PASS mets                         |
| 29  | 0.108560 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 530 Login incorrect.             |
| 32  | 0.120024 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 530 Login incorrect.             |
| 39  | 0.145896 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 530 Login incorrect.             |
| 47  | 0.195865 | 10.234.125.254 | 10.121.70.151  | FTP      | Request: PASS mgr                          |
| 52  | 0.207636 | 10.121.70.151  | 10.234.125.254 | FTP      | Response: 220 FTP Service                  |

Frame 4: 76 bytes on wire (608 bits), 76 bytes captured (608 bits) on interface 0  
Ethernet II, Src: 00:01:96:3c:3f:a8, Dst: 00:d0:59:aa:af:80  
Internet Protocol Version 4, Src: 10.121.70.151, Dst: 10.234.125.254  
Transmission Control Protocol, Src Port: 21, Dst Port: 2217, Seq: 300000000  
File Transfer Protocol (FTP)  
- 530 Login incorrect.\r\n  
Response code: Not logged in (530)  
Response arg: Login incorrect.  
[Current working directory: ]

- Rappel sur les protocoles
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- **Méthodologie de surveillance**
- Les outils d'investigation et de détection
- Méthodologie d'investigation

### Méthodologie de surveillance

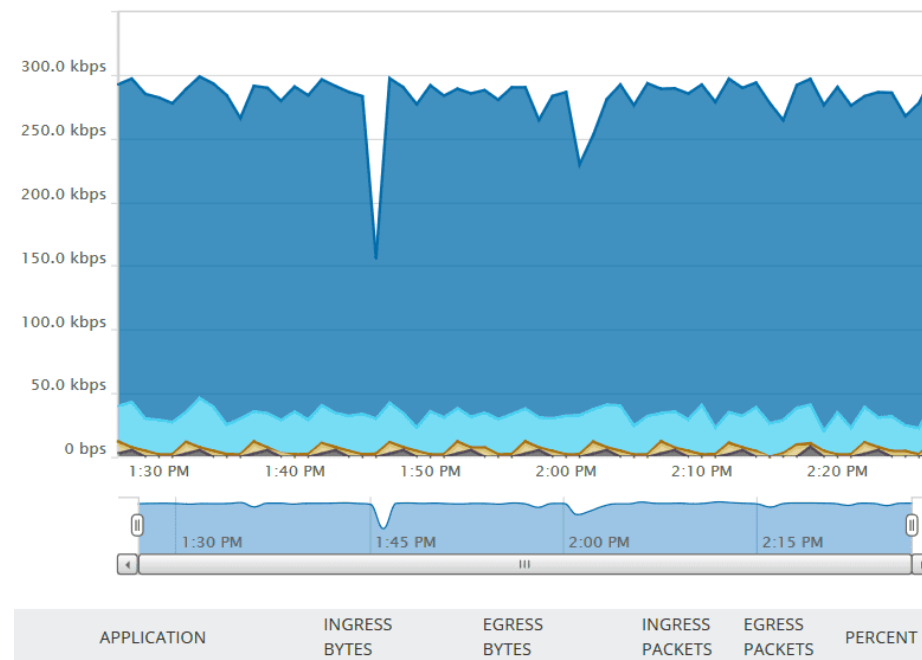


## Méthodologie de surveillance

### Capturer l'ensemble du trafic réseau :

Il est garanti qu'il n'existe aucune perte d'évènements.

En revanche, cette méthodologie gaspille du temps, et peut créer rapidement un vrai problème de volumétrie dans le temps.





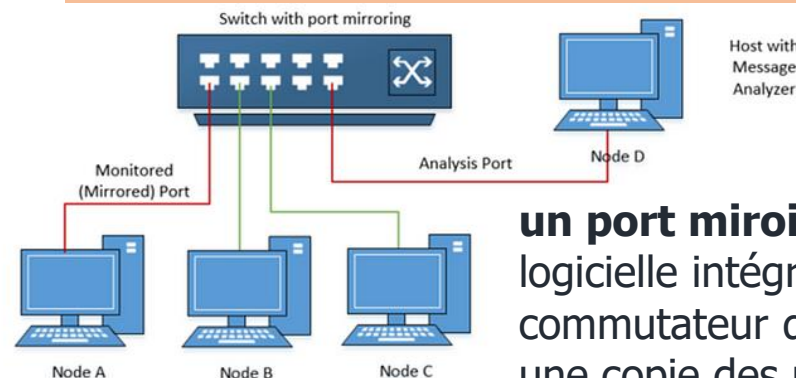
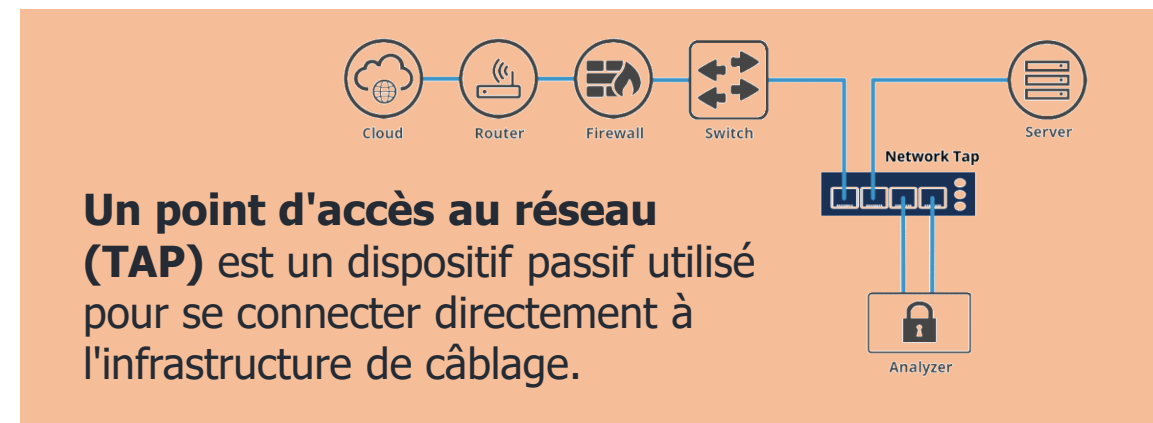
## Méthodologie de surveillance

## Capture &amp; Parse (CAP) :

Capturer uniquement les paquets suspects et méritant une analyse en profondeur

Cette méthode permet le contrôle de la volumétrie et du stockage. Cependant des évènements peuvent être ratés et nécessitera plus de ressources (*mise en place d'un TAP est préférable au port mirroring*). **Système passif**

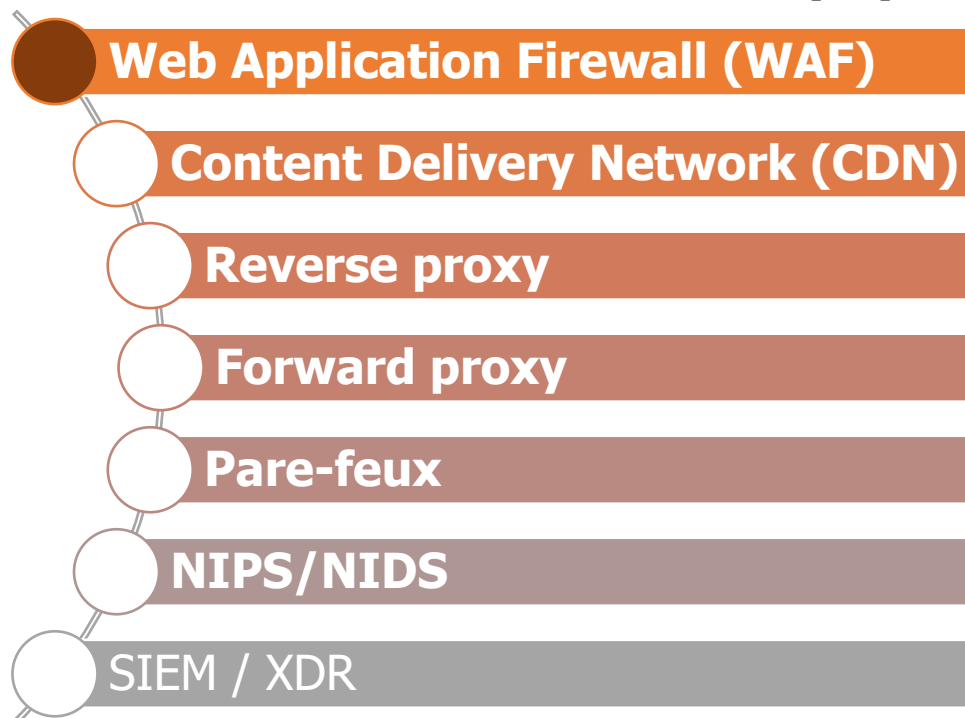
**Attention** : besoin fort niveau ressources (CPU) pour analyseur pour se rapprocher du temps réel.



**un port miroir** est une fonction logicielle intégrée dans un commutateur de réseau qui crée une copie des paquets sélectionnés passant par l'appareil et les envoie à un port miroir désigné.

## Techniques, tactiques et procédures des attaquants

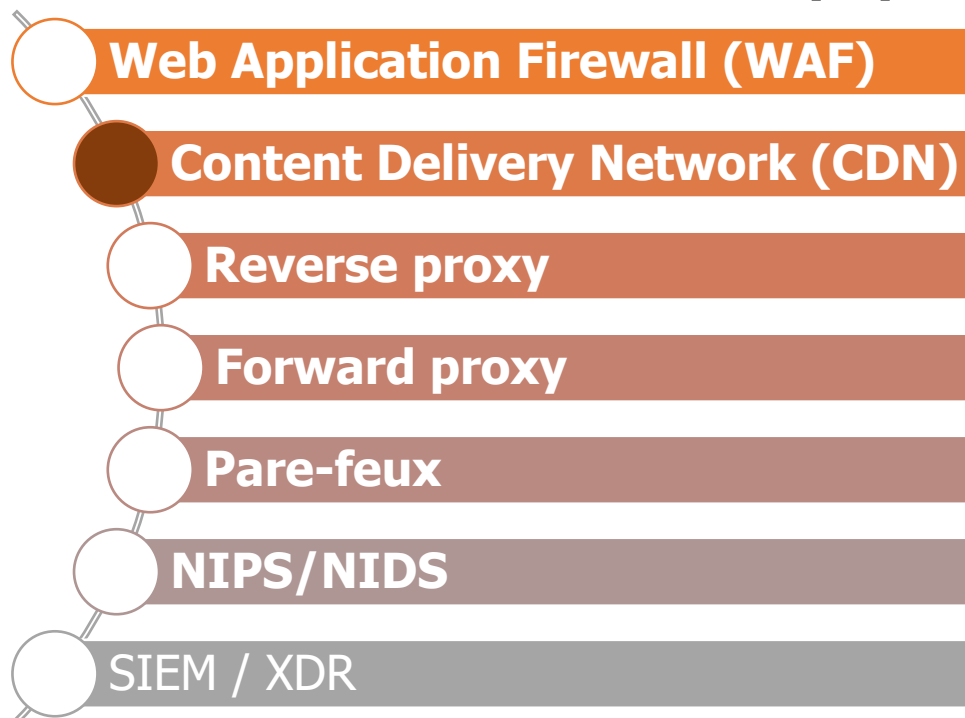
## Les équipements de sécurité indispensables

Web Application Firewall (WAF)

- **Fonction principale** : Un WAF protège les applications web contre les attaques ciblant leurs vulnérabilités. Exemples : SQL injection, cross-site scripting (XSS), falsification de requêtes côté serveur (SSRF).
- **Position dans l'architecture réseau** : Placé devant les applications web (souvent en tant que composant du reverse proxy ou du CDN). Il inspecte les requêtes HTTP/HTTPS avant qu'elles atteignent le serveur.
- **Objectif** : Sécuriser les applications en appliquant des politiques et en bloquant les requêtes malveillantes.

## Techniques, tactiques et procédures des attaquants

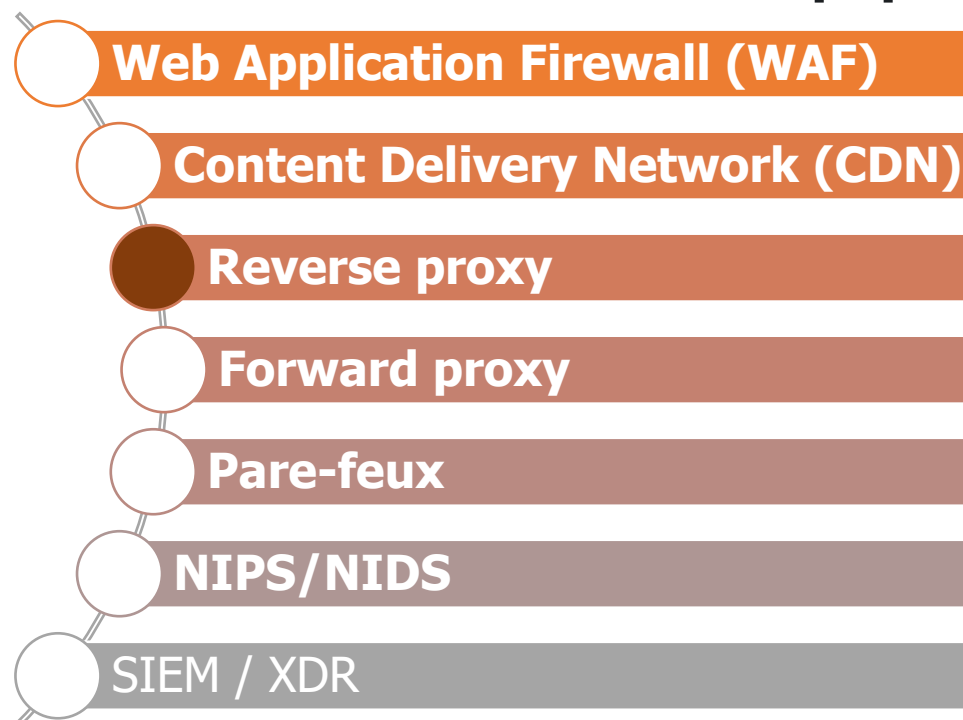
## Les équipements de sécurité indispensables

Content Delivery Network (CDN)

- **Fonction principale :** Un CDN améliore la performance et la disponibilité des applications web en distribuant leur contenu (images, vidéos, fichiers CSS/JS, etc.) à partir de serveurs géographiquement proches des utilisateurs finaux.
- **Position dans l'architecture réseau :** Placé entre les utilisateurs finaux et le serveur d'origine. Il sert de cache pour réduire la latence et la charge sur le serveur principal.
- **Objectif :** Optimiser les temps de réponse et la bande passante, et parfois offrir une protection DDoS basique.

## Techniques, tactiques et procédures des attaquants

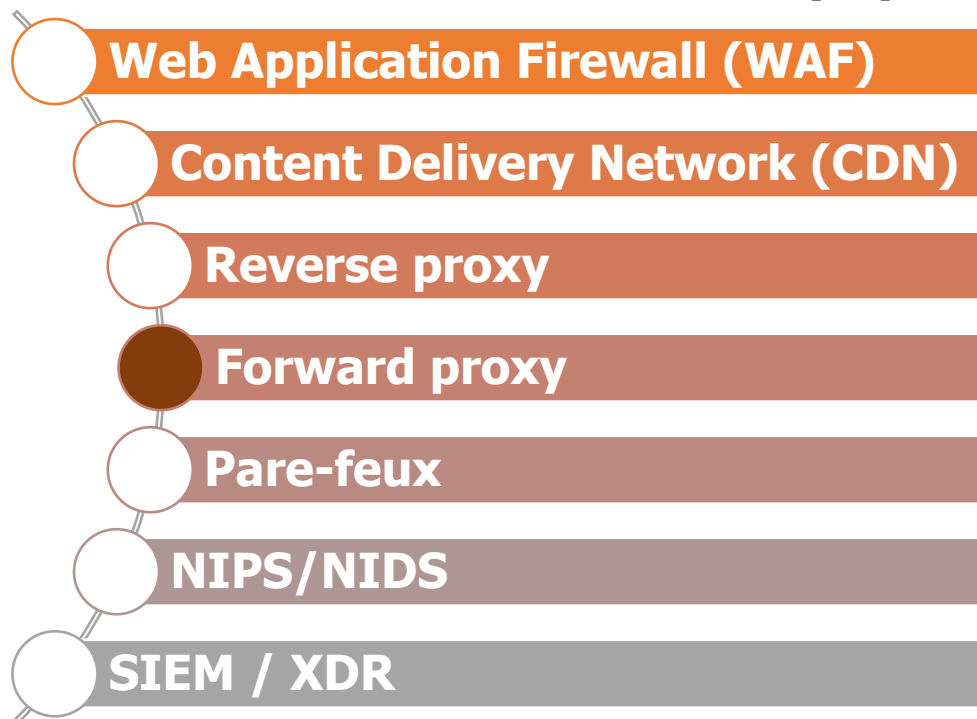
## Les équipements de sécurité indispensables

Reverse Proxy

- **Fonction principale** : Un reverse proxy est un serveur qui agit comme intermédiaire entre les utilisateurs finaux et les serveurs backend. Exemple : Nginx, HAProxy.
- **Position dans l'architecture réseau** : Placé devant un ou plusieurs serveurs backend. Il reçoit les requêtes des utilisateurs, les distribue aux serveurs appropriés, et retourne les réponses aux utilisateurs.
- **Objectif** : Répartition de charge, Mise en cache, Terminaison SSL, Sécurité (masquer les adresses IP des serveurs backend).

## Techniques, tactiques et procédures des attaquants

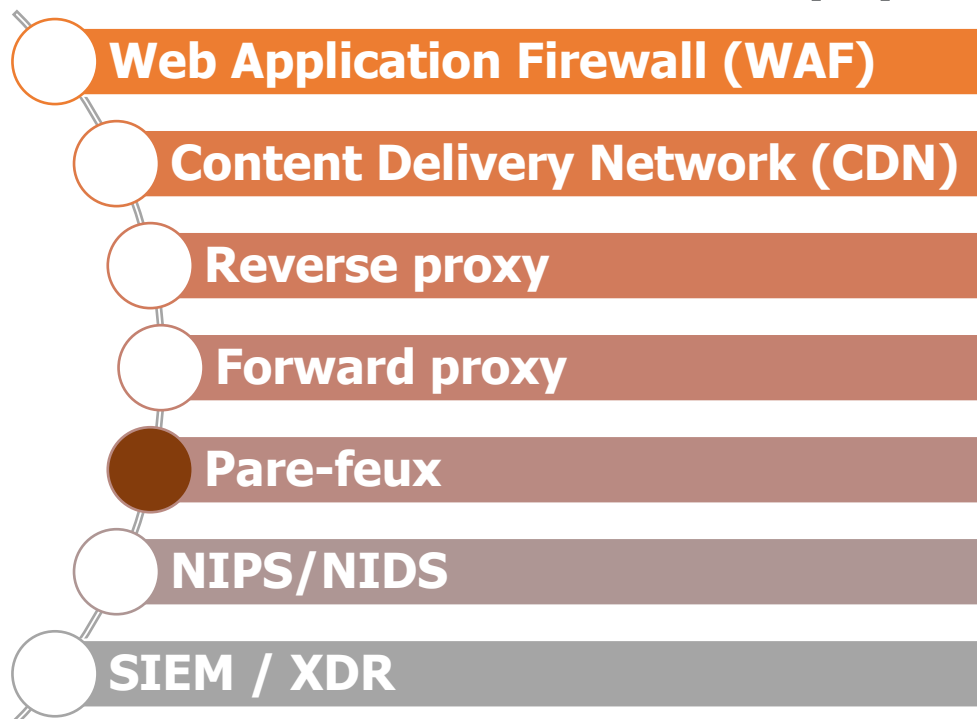
## Les équipements de sécurité indispensables

Forward Proxy

- **Fonction principale** : Un forward proxy agit au nom des utilisateurs pour accéder à des ressources externes. Il masque l'identité des utilisateurs et peut contrôler ou surveiller leurs accès.
- **Position dans l'architecture réseau** : Placé entre les utilisateurs et Internet. Exemple : Proxy utilisé pour accéder à des sites bloqués dans un réseau.
- **Objectif** : Contrôle d'accès (filtrage de contenu, blocage de sites), Anonymat des utilisateurs et Mise en cache pour optimiser la bande passante.

## Techniques, tactiques et procédures des attaquants

### Les équipements de sécurité indispensables



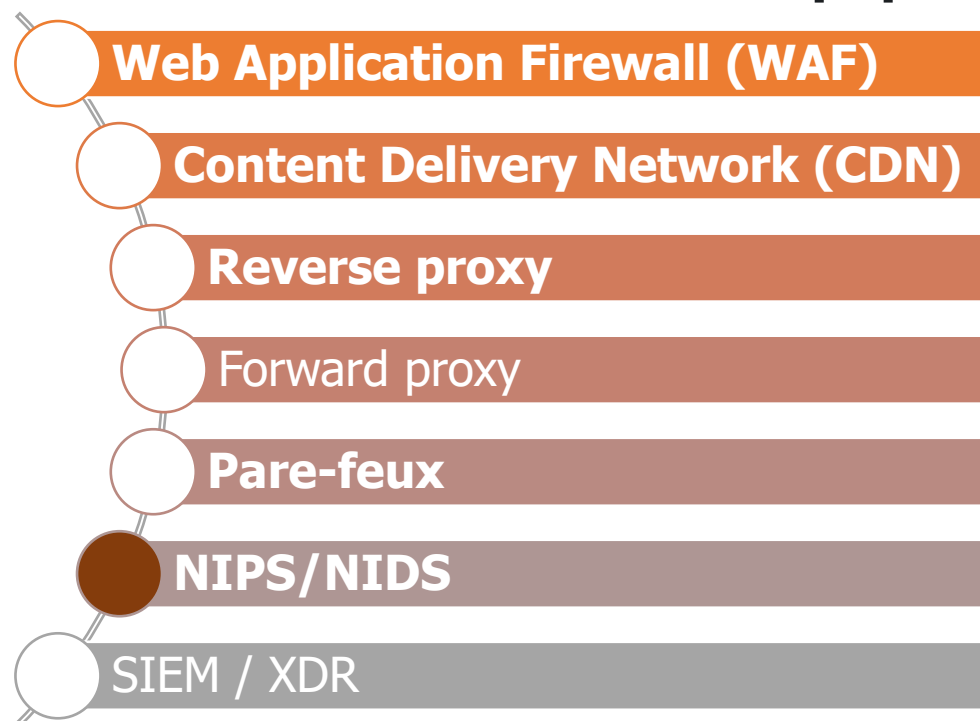
#### Pare-feu (Firewall)

- **Fonctionnalité principale** : Contrôle le trafic réseau entrant et sortant en appliquant des règles de sécurité. Il agit comme une barrière protectrice. Bloque ou autorise des paquets réseau en fonction de critères comme l'adresse IP, les ports, ou le protocole.
- **Types courants** :
  - **Pare-feu réseau** : Filtre le trafic entre réseaux (par exemple, entre un réseau interne et Internet).
  - **Pare-feu applicatif** : Protège les applications en examinant les données au niveau des couches supérieures (couche 7 OSI).



## Techniques, tactiques et procédures des attaquants

## Les équipements de sécurité indispensables

**NIPS (Network Intrusion Prevention System) / NIDS (Network Intrusion Detection System)**▪ **Fonction principale :**

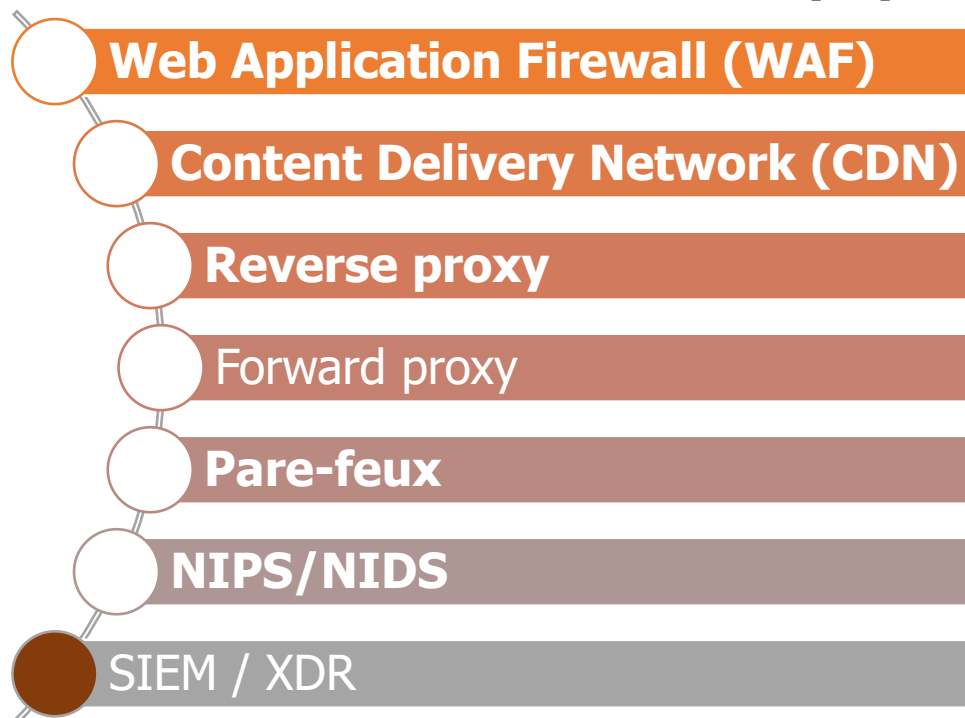
- **NIDS** : Détecte les activités suspectes ou malveillantes sur un réseau et alerte les administrateurs.
- **NIPS** : Empêche les attaques détectées en bloquant le trafic malveillant en temps réel.

▪ **Exemple d'utilisation :**

- Identifie les scans de ports ou les attaques DDoS.
- Arrête une connexion suspecte à partir d'une adresse IP malveillante.

## Techniques, tactiques et procédures des attaquants

### Les équipements de sécurité indispensables

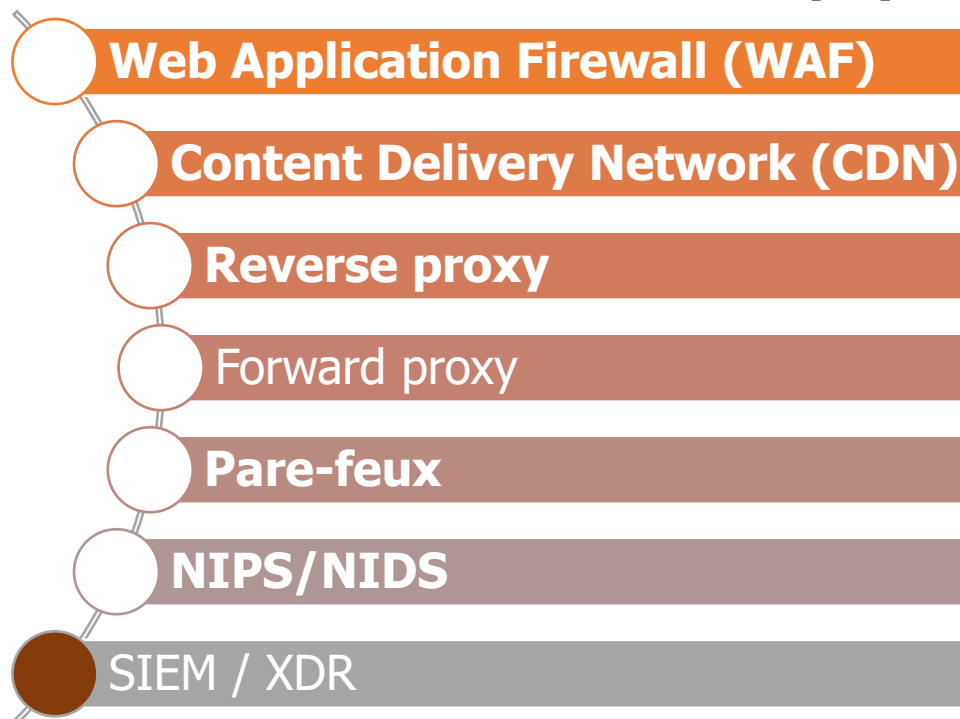


#### SIEM (Security Information and Event Management)

- **Fonction principale :** Collecte, corrèle et analyse les journaux provenant de différentes sources pour détecter des incidents de sécurité.
- **Exemple d'utilisation :**
  - Génère des alertes basées sur des comportements anormaux dans les logs.
  - Permet de répondre rapidement à un incident grâce à une vue centralisée.

## Techniques, tactiques et procédures des attaquants

### Les équipements de sécurité indispensables



#### XDR (Extended Detection and Response)

- **Fonction principale** : Offre une détection et une réponse plus approfondies en intégrant plusieurs couches de sécurité (endpoints, réseau, cloud, applications).
- **Cible** : Coordination des solutions de sécurité pour une réponse plus efficace.
- **Exemple d'utilisation** : Automatise les réponses à des menaces complexes (malwares avancés, attaques APT).

### Techniques, tactiques et procédures des attaquants

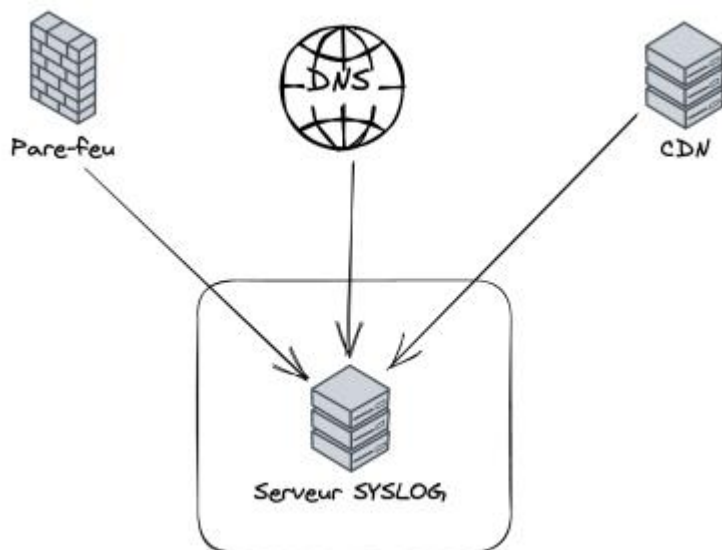
#### Les équipements de sécurité indispensables

| Caractéristiques         | WAF                        | CDN                    | Reverse Proxy              | Forward Proxy             |
|--------------------------|----------------------------|------------------------|----------------------------|---------------------------|
| <b>But principal</b>     | Sécurité (application web) | Accélération & cache   | Intermédiaire côté serveur | Intermédiaire côté client |
| <b>Protection</b>        | Attaques web               | DDoS basique           | Serveurs backend           | Utilisateurs              |
| <b>Emplacement</b>       | Devant l'appli web         | Entre client & serveur | Entre client & backend     | Entre client & Internet   |
| <b>Exemples d'outils</b> | AWS WAF, Cloudflare        | Cloudflare, Akamai     | Nginx, HAProxy             | Squid, Privo              |

40

## Techniques, tactiques et procédures des attaquants

### Intégrer les équipements réseau à la collecte centralisée



Les équipements réseaux possèdent en général un connecteur rsyslog

Il est parfois nécessaire d'effectuer un travail de normalisation des journaux une fois ces derniers centralisés.

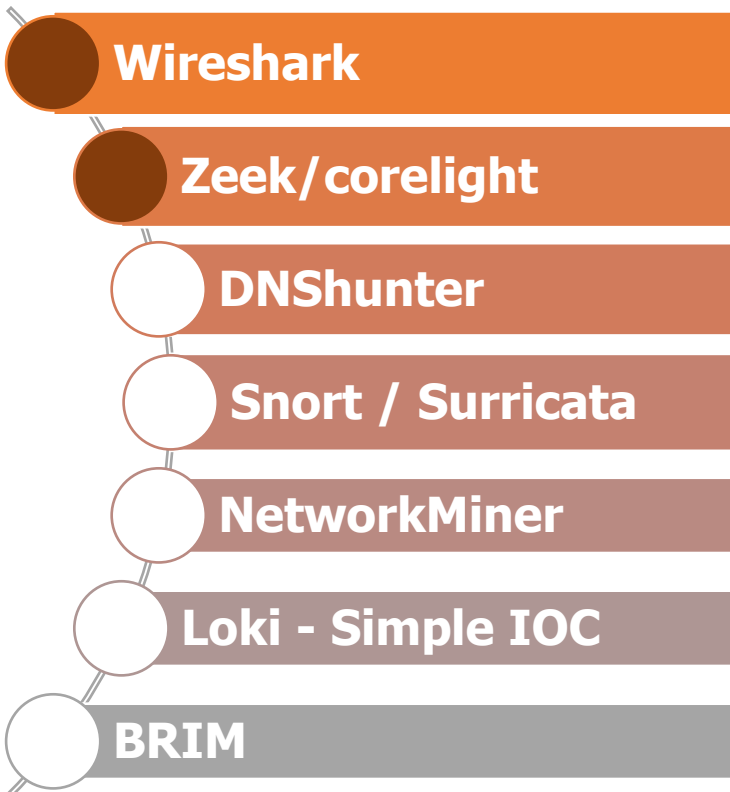
Réfléchir à la l'interconnexion éventuelle avec un SOC (interne ou externe).

- Rappel sur les protocoles
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- **Les outils d'investigation et de détection**
- Méthodologie d'investigation

### Les outils d'investigation et de détection



## Les outils d'investigation et de détection

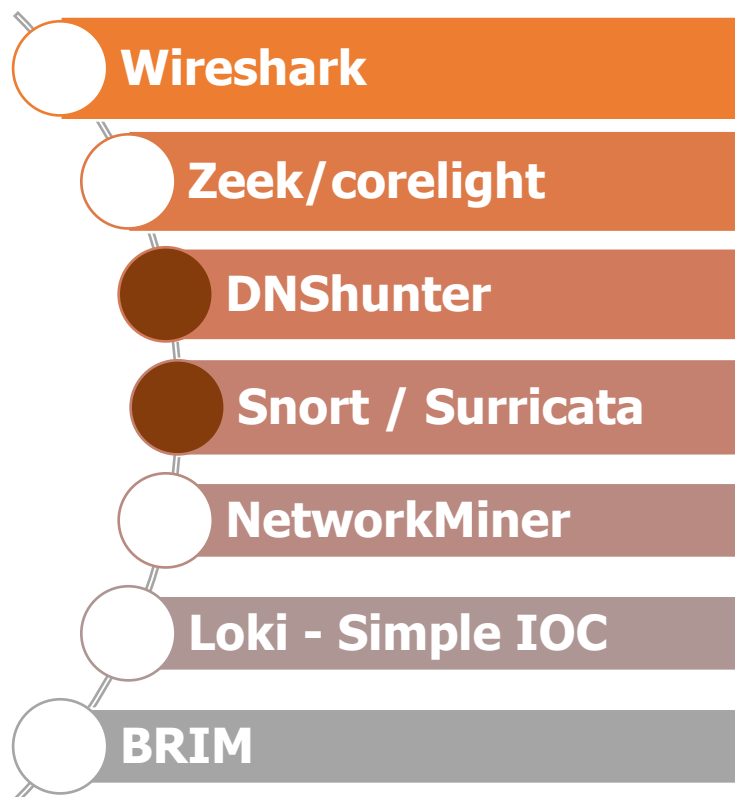
**Wireshark****Zeek/corelight****DNShunter****Snort / Suricata****NetworkMiner****Loki - Simple IOC****BRIM**

**Wireshark** est un outil open source populaire utilisé pour capturer et analyser le trafic réseau en temps réel. Il est largement employé par les administrateurs réseau, les analystes en cybersécurité, et les chercheurs pour diagnostiquer des problèmes réseau, enquêter sur des incidents de sécurité, ou mieux comprendre les protocoles réseau.

**Zeek** est un puissant cadre logiciel (framework) pour l'analyse et la surveillance du trafic réseau. Initialement développé en tant que système de détection d'intrusion (IDS), il a évolué pour devenir une plateforme flexible utilisée pour une analyse approfondie des réseaux.



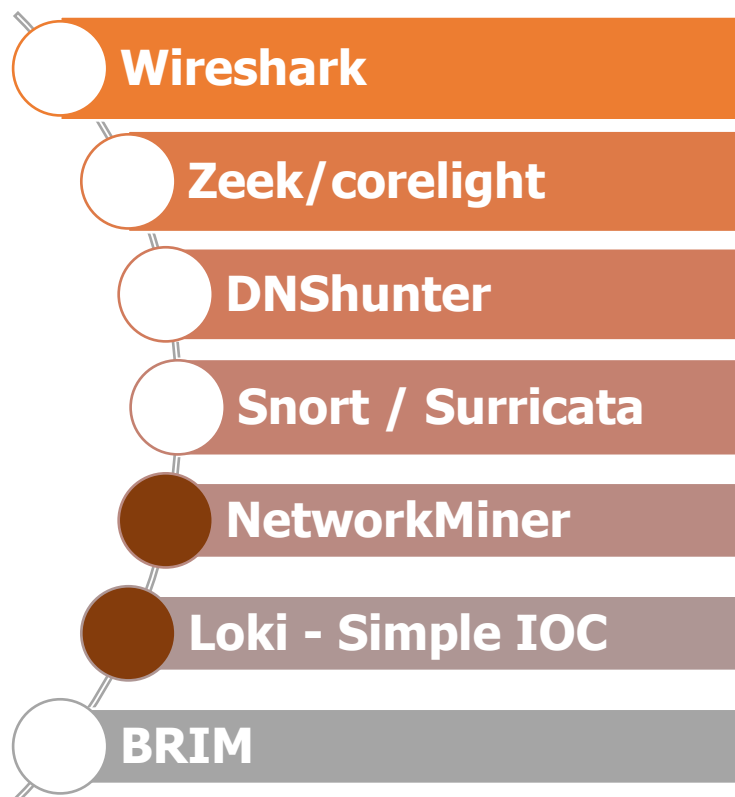
## Les outils d'investigation et de détection



**DNSHunter** est un outil spécialisé pour analyser et détecter des anomalies dans le trafic DNS, souvent utilisé dans le cadre d'investigations sur des activités malveillantes ou des problèmes réseau. Il est conçu pour aider les analystes en cybersécurité et les équipes de réponse aux incidents (CSIRT) à examiner le trafic DNS et à identifier des comportements potentiellement malveillants ou anormaux.

**Snort** et **Suricata** sont deux outils populaires de détection et prévention d'intrusion (IDS/IPS). Ils jouent un rôle essentiel dans la sécurité réseau en surveillant le trafic pour détecter et prévenir des menaces.

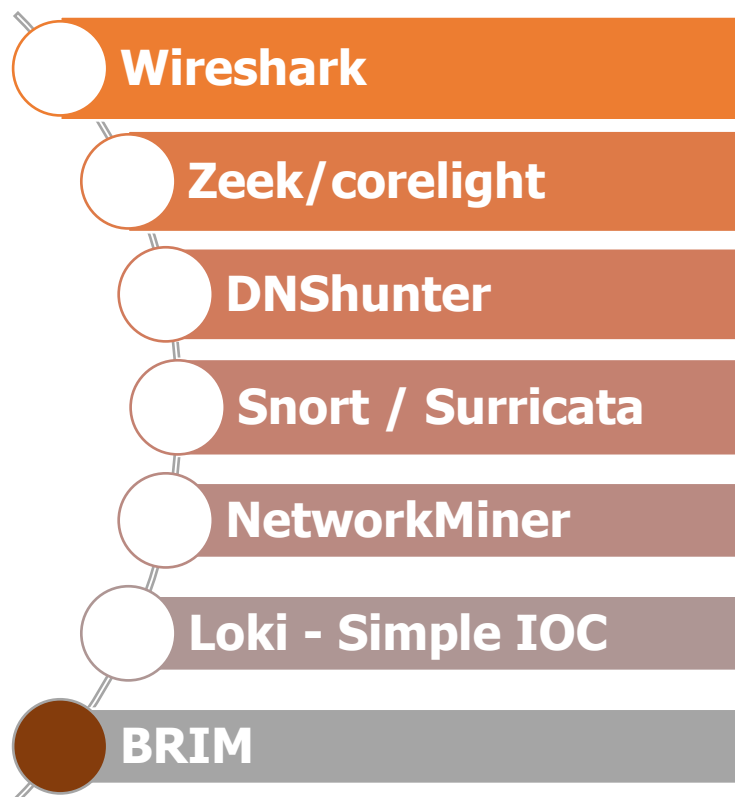
## Les outils d'investigation et de détection



**NetworkMiner** est un outil de surveillance réseau et d'analyse forensic utilisé pour la collecte de données réseau passives et la reconstruction d'informations utiles à partir de ces données. Logiciel open source, il est particulièrement populaire dans le domaine de la cybersécurité pour effectuer des investigations post-incident et analyser des fichiers de capture réseau (PCAP).

**Loki** est un scanner open source conçu pour détecter des **Indicators of Compromise (IOC)** sur un système. Développé par Florian Roth, il est léger, facile à utiliser, et axé sur la détection des signes d'activités malveillantes ou suspectes sur des systèmes hôtes.

## Les outils d'investigation et de détection



**Brim** est une plateforme open source moderne conçue pour faciliter l'analyse et la gestion de grandes quantités de données réseau, comme les fichiers de capture (PCAP) ou les journaux réseau. Elle intègre des outils de surveillance réseau avancés, notamment **Zeek** et **Suricata**, dans une interface graphique conviviale, et permet aux analystes de sécurité et aux administrateurs réseau d'explorer efficacement les données de trafic réseau.

### Les outils d'investigation et de détection

- Wireshark (<https://www.wireshark.org/>)
- Zeek/corelight (<https://corelight.com/products/compare-to-zeek>)
- DNShunter (<https://github.com/slacker007/DNShunter>)
- Snort / Suricata (<https://www.snort.org/> - <https://suricata.io/>)
- NetworkMiner (<https://www.netresec.com/?page=NetworkMiner>)
- BRIM (<https://www.brimdata.io/>)
- Loki - Simple IOC (<https://github.com/Neo23x0/Loki>)

- Rappel sur les protocoles
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- **Méthodologie d'investigation**

### Méthodologie d'investigation



1. L'observation



2. La problématisation



3. La recherche d'hypothèses



4. L'investigation



5. Echange argumenté



6. La conclusion



7. L'évaluation

48

### Méthodologie d'investigation dans le cadre d'un incident

Planifier l'enquête

Collecter et documenter les artefacts réseau.

Filtrez les données.

Analyser les artefacts réseau.

Identifier la source de l'attaque et extraire les indicateurs, techniques, tactiques et procédures.

Documenter vos activités et proposer vos conclusions.

Présenter les résultats.

Présenter les mesures de remédiation.

### Conclusions et limites

Collecte et stockage des journaux

Difficulté d'interprétation

Manque d'informations contextuelles



50

# Merci de votre attention

## A votre disposition pour un approfondissement

**Maître de conférences associé**

**Doctorant en intelligence artificielle**

Ecole doctorale MITT Mathématiques Informatique  
Télécommunications de Toulouse.

Laboratoire IRIT - Equipe SMAC

Systèmes Multi-Agents Coopératifs

Avenue de l'étudiant, 31400 Toulouse

Courriel : [fabrice.crasnier@irit.fr](mailto:fabrice.crasnier@irit.fr)



UNIVERSITE  
TOULOUSE III  
PAUL SABATIER



Université  
de Toulouse

Faculté  
Sciences  
et Ingénierie

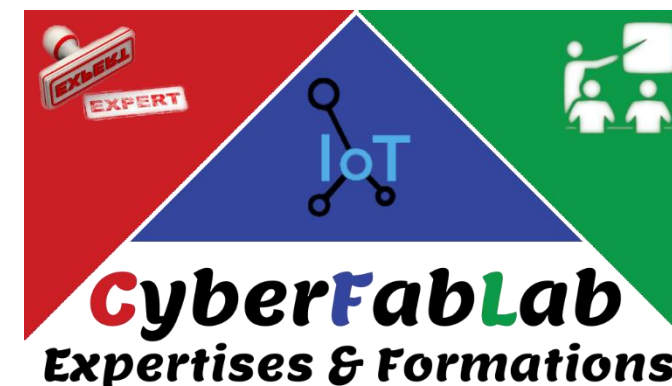
### Domaines de compétences

- ☐ Formations en cybersécurité
- ☐ Réponse sur incident de sécurité
- ☐ Gestion de crise, conseil juridique
- ☐ Construction d'un dossier de plainte
- ☐ Expertises pénales et civiles



Ecole Doctorale Mathématiques, Informatique  
et Télécommunications de Toulouse

Expert en Cybersécurité



Tel : 06.24.49.39.20

Courriel : [fabrice.crasnier@cyberfablab.fr](mailto:fabrice.crasnier@cyberfablab.fr)